

Boss of the SOC

Corelight Partner Experience

CTF Investigation Writeup

Mehenni May

March 16, 2026

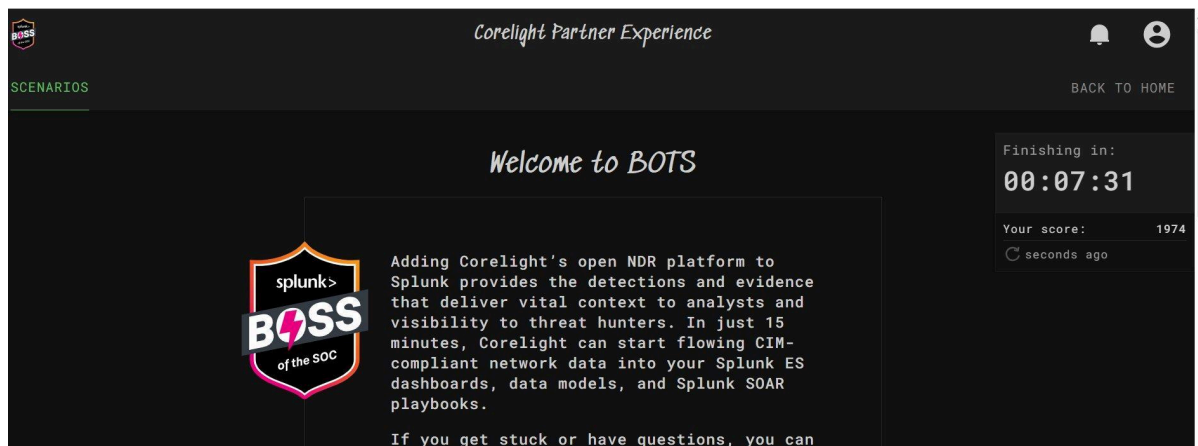


Figure 1 — Splunk Boss of the SOC: Corelight Partner Experience platform (Score: 1974)

Introduction

This report documents my participation in the Splunk Boss of the SOC (BOTS) Corelight Partner Experience — a Capture The Flag (CTF) challenge designed to simulate real-world SOC analyst workflows using network detection and response (NDR) data. The challenge is built on top of Splunk Enterprise with the Corelight app, providing CIM-compliant Zeek network logs and Suricata IDS alerts from a simulated enterprise environment.

The index used throughout all challenges is `index=corelight`. Data spans 226,463 events captured on September 24, 2021, originating from a SmartPCAP sensor named `SmartPCAP_192_168_5_1`. The investigation follows a Trickbot malware infection from initial detection through post-infection lateral movement and reconnaissance.

Methodology & Documentation Format

Due to the 15-minute time constraint of the live CTF session, I focused my effort on questions #101 through #113, completing them in full depth — including query construction, raw log analysis, and threat intelligence extraction. The remaining questions beyond #113 were not reached before the timer expired, not due to a lack of ability, but simply because the challenge was deliberately scoped to test speed and accuracy under pressure. The methodology demonstrated across these 13 questions is fully transferable to any remaining items.

Each question was solved by following a structured workflow:

1. Formulate a hypothesis and identify the relevant Corelight sourcetype (e.g., `corelight_suricata_corelight`, `corelight_http`, `corelight_conn`, `corelight_notice`).
2. Write and execute a targeted Splunk SPL query to extract relevant fields.
3. Inspect raw event details to confirm the finding.
4. Submit the answer and document: (a) the question card with confirmed answer, then (b) the supporting Splunk queries and result screenshots.

Each section below follows this exact format: the question card screenshot (showing the challenge prompt and the verified correct answer) is presented first, followed by one or more screenshots showing the Splunk query and its results. This mirrors the investigative sequence used during the live CTF.

Findings Summary

The table below summarizes all 13 questions answered, the key finding for each, and the correct answer.

#	Question Summary	Answer
101	Total Suricata alerts in the index	47
102	IP address of host generating most alerts	10.0.0.31
103	Malware family identified by alerts	Trickbot
104	UID shared by 3 Trickbot alerts on one TCP stream	CAoNRI62m9CRqS0R2

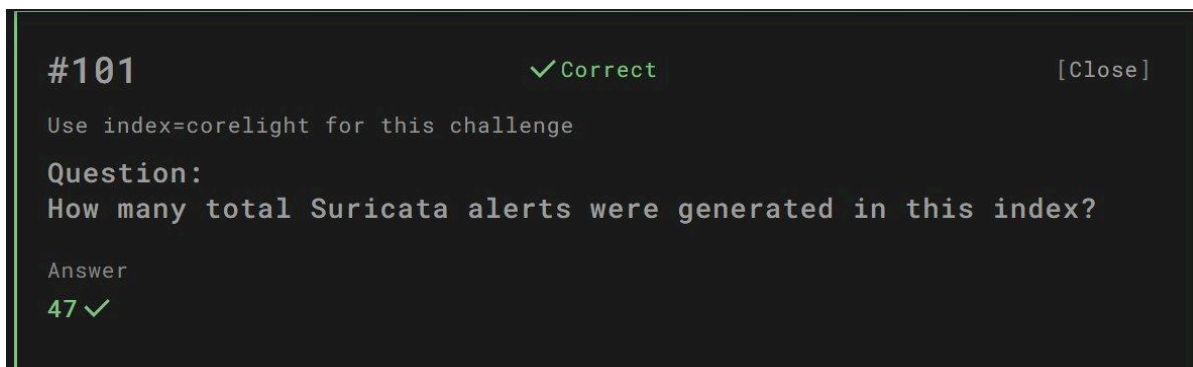
105	IP address of the malicious C2 server	103.16.104.83
106	Layer 7 protocol carrying the Trickbot traffic	http
107	MITRE ATT&CK TTP referenced in the notice log	S0266
108	User-Agent string in Trickbot HTTP requests	Ghost
109	Process name repeated in the POST body	svchost.exe
110	Scanning tool used for post-infection reconnaissance	Nessus
111	Bytes sent back by target in WAP exploit attempt	0
112	Internal host targeted via SSH after infection	10.0.0.72
113	PCR (producer/consumer ratio) of that SSH session	0.85198

Question #101 — Total Suricata Alerts

How many total Suricata alerts were generated in the index=corelight index?

Answer: 47

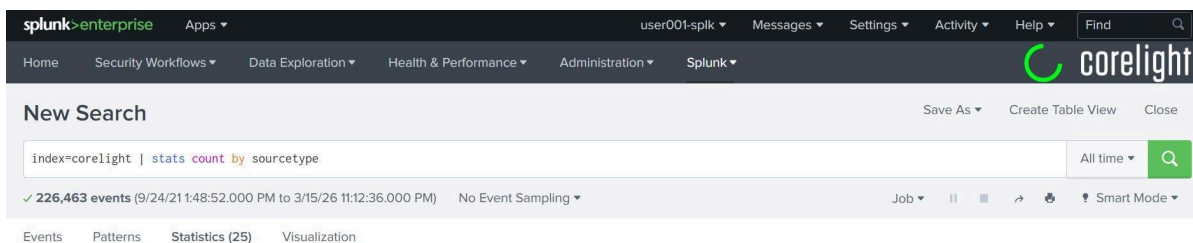
Step 1 — Question Card



Q#101: Question card showing confirmed answer of 47 total Suricata alerts

Step 2 — SPL Query: Count Events by Sourcetype

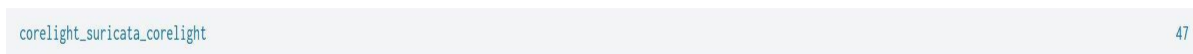
Query: `index=corelight | stats count by sourcetype` — This enumerates all sourcetypes in the index. The sourcetype `corelight_suricata_corelight` stores Suricata IDS alert events.



Q#101: Splunk query "index=corelight | stats count by sourcetype" across 226,463 total events

Step 3 — Result

The result shows `corelight_suricata_corelight` with a count of 47 events, confirming 47 total Suricata alerts.



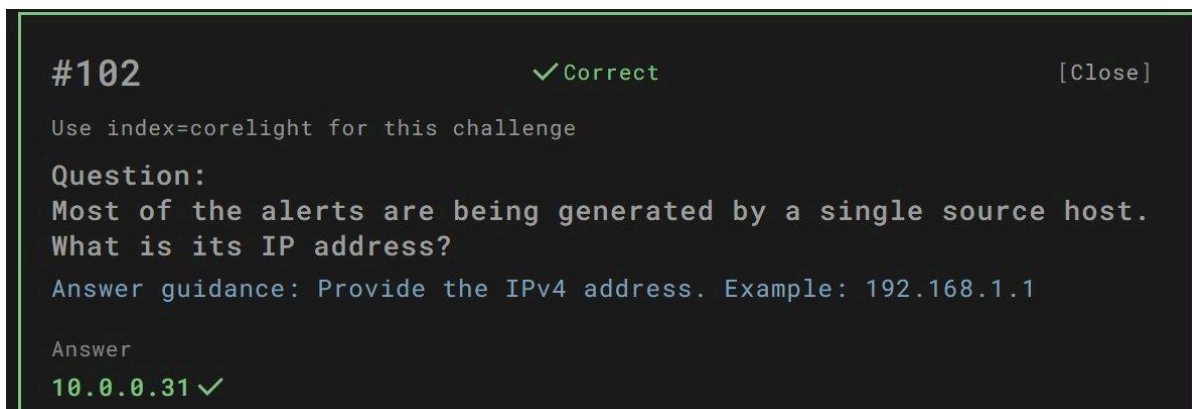
Q#101: Result row — `corelight_suricata_corelight`: 47 events

Question #102 — Top Alert-Generating Source Host

Most of the alerts are being generated by a single source host. What is its IP address?

Answer: 10.0.0.31

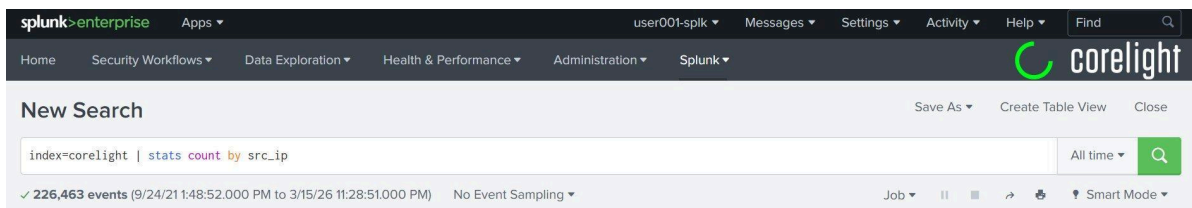
Step 1 — Question Card



Q#102: Question card showing confirmed answer of 10.0.0.31

Step 2 — SPL Query: Count by Source IP

Query: `index=corelight | stats count by src_ip` — This aggregates events by originating IP address to identify the most active internal host.



Q#102: Splunk query "index=corelight | stats count by src_ip" across 226,463 events

Step 3 — Result

The host 10.0.0.31 is responsible for 224,755 events — by far the most active host in the dataset, indicating a compromised endpoint generating significant malicious traffic.

10.0.0.31	224755
-----------	--------

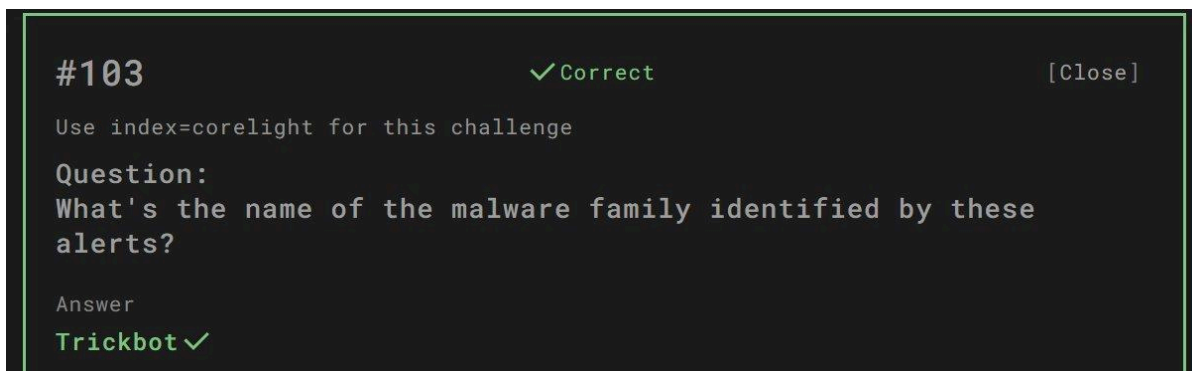
Q#102: Result row — 10.0.0.31: 224,755 events

Question #103 — Malware Family Identification

What is the name of the malware family identified by these alerts?

Answer: Trickbot

Step 1 — Question Card



Q#103: Question card showing confirmed answer of "Trickbot"

Step 2 — SPL Query: Suricata Signatures by Count

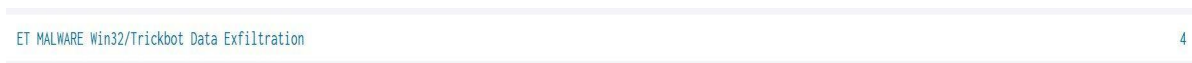
Query: `index=corelight sourcetype="corelight_suricata_corelight" | stats count by alert.signature`
— This lists all unique Suricata alert signatures with their frequency. The "ET MALWARE Win32/Trickbot Data Exfiltration" signature immediately identifies the malware family.



Q#103: Splunk query listing all 19 unique Suricata signatures across 47 alert events

Step 3 — Result

The signature "ET MALWARE Win32/Trickbot Data Exfiltration" appears 4 times, identifying Trickbot as the malware family behind the infection.



Q#103: Result row — "ET MALWARE Win32/Trickbot Data Exfiltration": 4 occurrences

Question #104 — Shared UID Across Trickbot Alerts

Three of the Trickbot Data Exfiltration alerts share a single UID, meaning they all occurred on a single TCP stream. What is that UID?

Answer: CAoNRI62m9CRqS0R2

Step 1 — Question Card

#104

✓ Correct

[Close]

Use index=corelight for this challenge

Question:
Let's take a closer look at the "ET MALWARE Win32/Trickbot Data Exfiltration" alerts. You'll notice that three of the alerts share a single UID, meaning they all occurred on a single TCP stream. What is that UID?

Answer
CAoNRI62m9CRqS0R2 ✓

Q#104: Question card showing confirmed answer of UID "CAoNRI62m9CRqS0R2"

Step 2 — SPL Query: Extract UIDs from Trickbot Alerts

Query: index=corelight alert.signature="ET MALWARE Win32/Trickbot Data Exfiltration" | table uid — This extracts the Zeek connection UID (uid) for each Trickbot alert. Three of the four results share the same UID, indicating three alerts occurred on the same TCP session. The fourth has a distinct UID.

splunk>enterprise		Apps	user001-splk	Messages	Settings	Activity	Help	Find
Home	Security Workflows	Data Exploration	Health & Performance	Administration	Splunk	corelight		
New Search								
index=corelight alert.signature="ET MALWARE Win32/Trickbot Data Exfiltration" table uid								All time
✓ 4 events (9/24/21 1:48:52.000 PM to 3/15/26 11:34:08.000 PM) No Event Sampling								
Events	Patterns	Statistics (4)	Visualization					
20 Per Page Format Preview								
uid								
CAoNRI62m9CRqS0R2								
CAoNRI62m9CRqS0R2								
CAoNRI62m9CRqS0R2								
CAxYSR26jP6LeD4z1e								

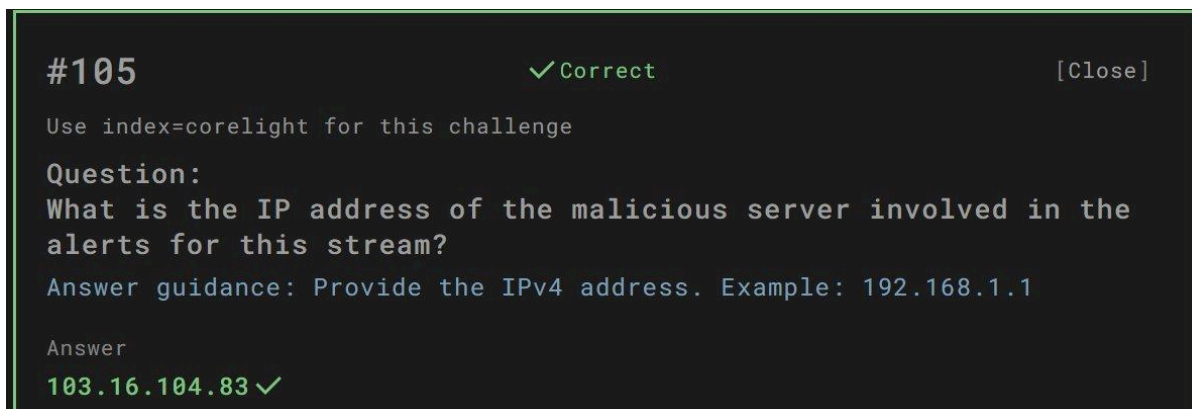
Q#104: Splunk table showing 4 alert UIDs — 3 share "CAoNRI62m9CRqS0R2", 1 is distinct ("CAxYSR26jP6LeD4z1e")

Question #105 — Malicious C2 Server IP

What is the IP address of the malicious server involved in the alerts for this stream?

Answer: 103.16.104.83

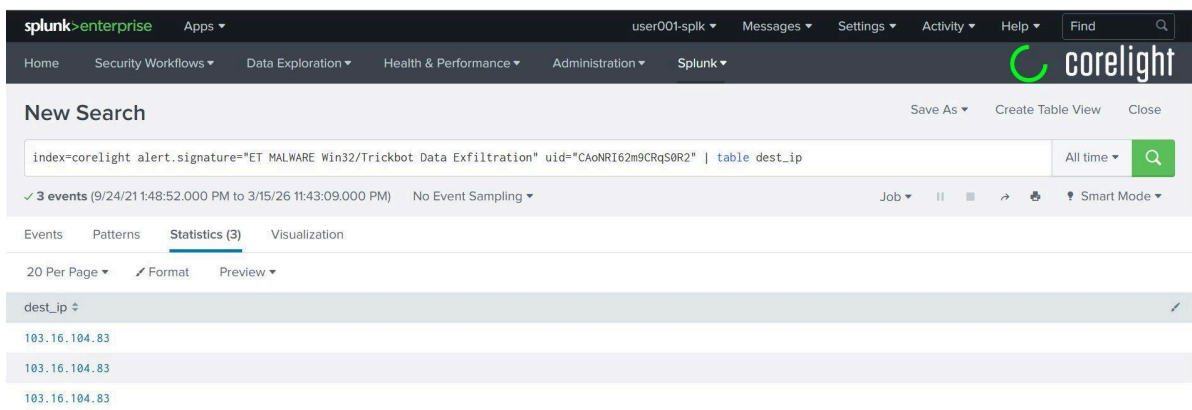
Step 1 — Question Card



Q#105: Question card showing confirmed C2 server IP 103.16.104.83

Step 2 — SPL Query: Destination IP from Shared UID

Query: `index=corelight alert.signature="ET MALWARE Win32/Trickbot Data Exfiltration" uid="CAoNRI62m9CRqS0R2" | table dest_ip` — Filtering by the shared UID isolates the three co-occurring alerts and reveals their common destination IP — the Trickbot C2 server.



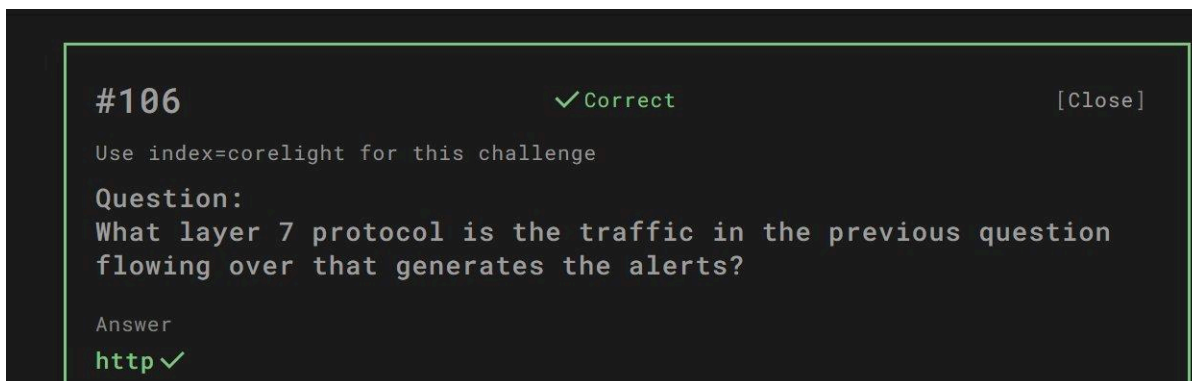
Q#105: Splunk table showing dest_ip 103.16.104.83 for all 3 alerts on the shared TCP stream

Question #106 — Layer 7 Protocol

What layer 7 protocol is the Trickbot traffic flowing over that generates the alerts?

Answer: http

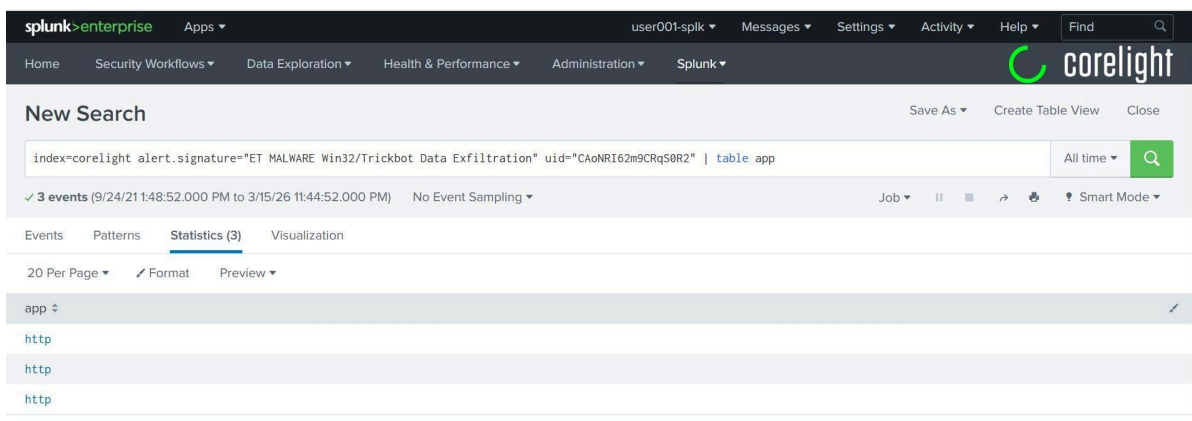
Step 1 — Question Card



Q#106: Question card confirming the Layer 7 protocol is "http"

Step 2 — SPL Query: Application Protocol Field

Query: index=corelight alert.signature="ET MALWARE Win32/Trickbot Data Exfiltration" uid="CAoNRI62m9CRqS0R2" | table app — The "app" field in Corelight logs contains the Zeek-identified layer 7 application protocol. All three alerts show "http", confirming Trickbot communicates with its C2 over plain HTTP.



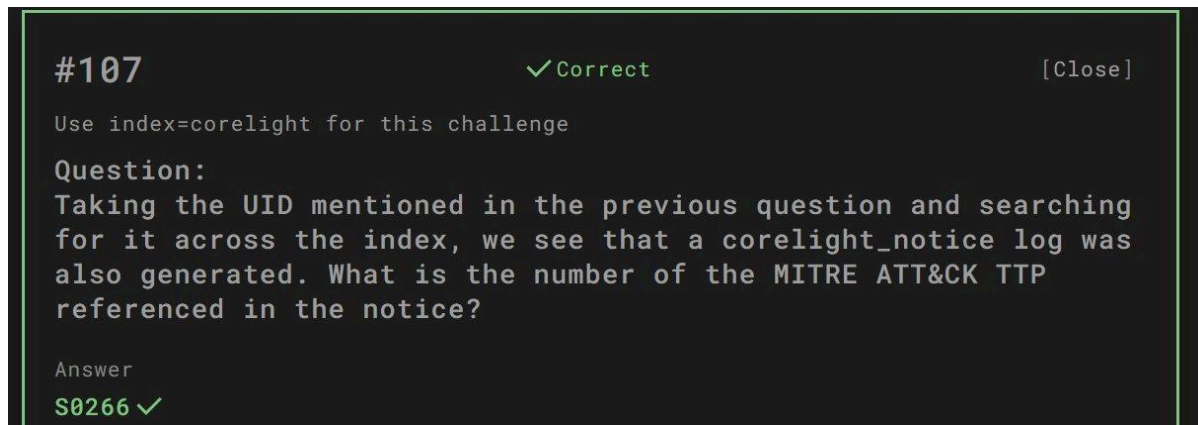
Q#106: Splunk table showing "app: http" for all 3 Trickbot alert events on the shared stream

Question #107 — MITRE ATT&CK TTP in Notice Log

Taking the UID from the previous question and searching for it across the index, a corelight_notice log was also generated. What is the MITRE ATT&CK TTP number referenced in the notice?

Answer: S0266

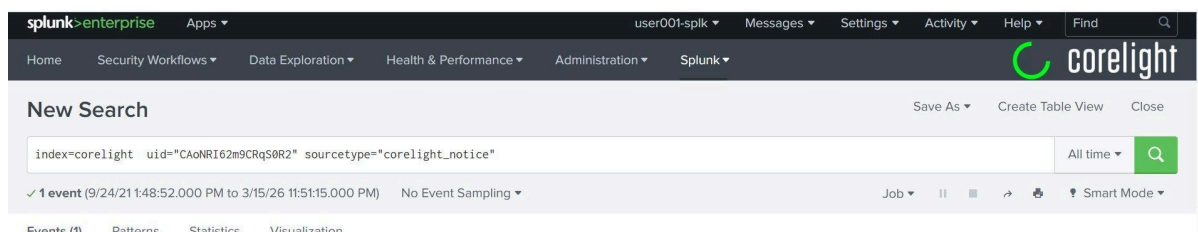
Step 1 — Question Card



Q#107: Question card confirming MITRE ATT&CK software ID S0266 (Trickbot)

Step 2 — SPL Query: Corelight Notice Log for the UID

Query: `index=corelight uid="CAoNRI62m9CRqS0R2" sourcetype="corelight_notice"` — Searching the shared UID across all sourcetypes finds a corelight_notice event generated by Corelight's built-in HTTP C2 detection algorithm.



Q#107: Splunk search for UID in corelight_notice — returns 1 event (9/24/21 1:54:48 PM)

Step 3 — Notice Event Detail

The notice event's "msg" field references: "Potential C2 traffic - Trickbot Malware <https://attack.mitre.org/software/S0266/>". S0266 is the MITRE ATT&CK Software ID for Trickbot. The note field confirms the detection type: HTTP_C2::C2_Traffic_Observed (Algorithm 1). The severity level is 1 (alert).

i	Time	Event
>	9/24/21 1:54:48.849 PM	<pre>{ [-] _path: notice _system_name: SmartPCAP_192_168_5_1 _write_ts: 2021-09-24T13:54:48.849621Z actions: [[+]] dst: 103.16.104.83 id.orig_h: 10.0.0.31 id.orig_p: 55842 id.resp_h: 103.16.104.83 id.resp_p: 443 msg: Potential C2 traffic - Trickbot Malware https://attack.mitre.org/software/S0266/. This detection is based on attributes within the http connection, further details can be found in http.log and conn.log - the relevant log lines will share the same uid as this notice. (Algorithm 1) note: HTTP_C2::C2_Traffic_Observed p: 443 peer_descr: worker-08 proto: tcp severity.level: 1 severity.name: alert src: 10.0.0.31 suppress_for: 3600</pre>

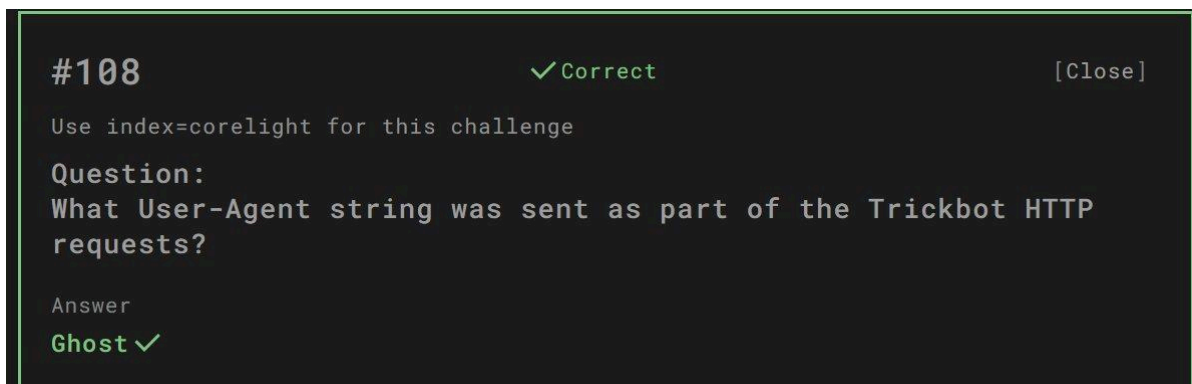
Q#107: Notice event detail — msg field references MITRE S0266 (Trickbot), note: HTTP_C2::C2_Traffic_Observed

Question #108 — Trickbot User-Agent String

What User-Agent string was sent as part of the Trickbot HTTP requests?

Answer: Ghost

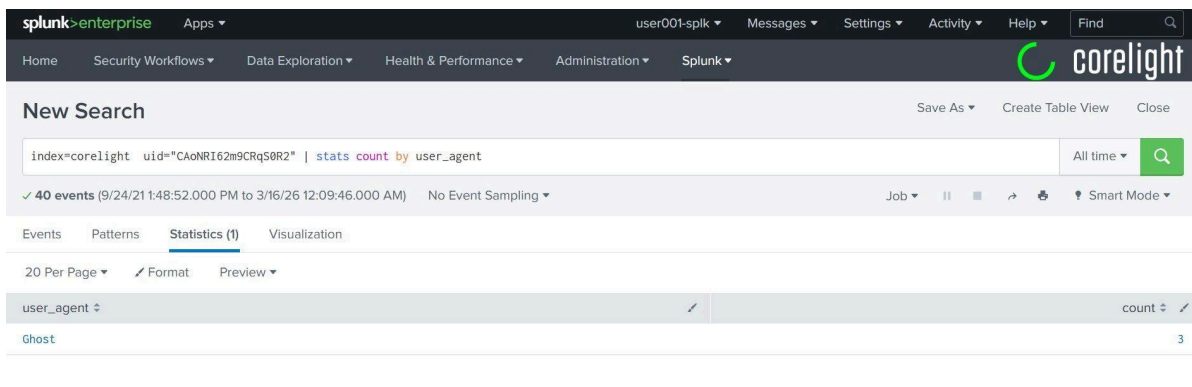
Step 1 — Question Card



Q#108: Question card confirming User-Agent "Ghost" for Trickbot HTTP requests

Step 2 — SPL Query: User-Agent on the Shared UID

Query: index=corelight uid="CAoNRI62m9CRqS0R2" | stats count by user_agent — Pivoting from the Suricata alert UID to the corelight_http log, this query extracts the HTTP User-Agent header used across the 3 POST requests. The single distinct value "Ghost" (appearing 3 times) confirms that Trickbot uses a custom User-Agent string to identify its C2 HTTP requests, which is a known Trickbot behavioral indicator.



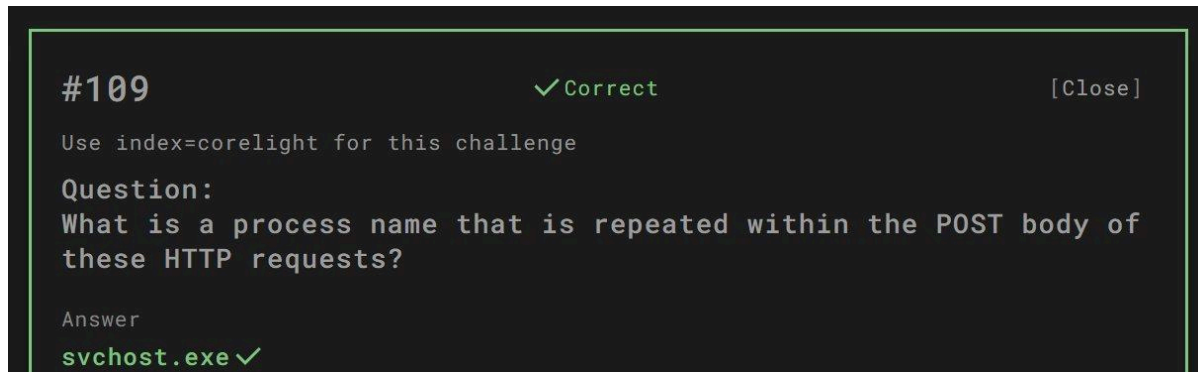
Q#108: Splunk stats showing user_agent "Ghost" with count 3 — all 3 HTTP requests use this string

Question #109 — Repeated Process in POST Body

What is a process name that is repeated within the POST body of these HTTP requests?

Answer: svchost.exe

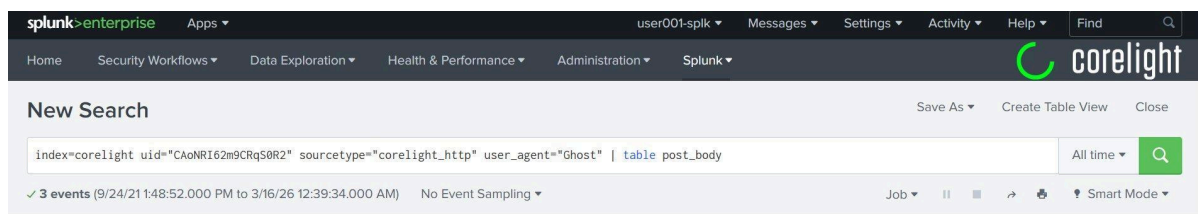
Step 1 — Question Card



Q#109: Question card confirming "svchost.exe" as the repeated process in the POST body

Step 2 — SPL Query: POST Body Contents

Query: `index=corelight uid="CAoNRI62m9CRqS0R2" sourcetype="corelight_http" user_agent="Ghost" | table post_body` — This retrieves the full POST body content from the 3 Trickbot HTTP requests filtered to the Ghost user_agent. The POST body contains the process list exfiltrated from the infected host.



Q#109: Splunk query to extract the `post_body` field from Trickbot HTTP POST requests (3 events)

Step 3 — POST Body Process List

The POST body reveals a list of running Windows processes exfiltrated to the C2 server, including: [System Process], System, Registry, smss.exe, csrss.exe, wininit.exe, winlogon.exe, services.exe, lsass.exe, and multiple instances of svchost.exe. The repeated appearance of svchost.exe (which Trickbot is known to inject into) confirms the process list exfiltration behavior described by MITRE S0266.

post_body ▾

```
[System Process]
System
Registry
smss.exe
csrss.exe
wininit.exe
csrss.exe
winlogon.exe
services.exe
lsass.exe
svchost.exe
svchost.exe
fontdrvhost.exe
fontdrvhost.exe
svchost.exe
svchost...
```

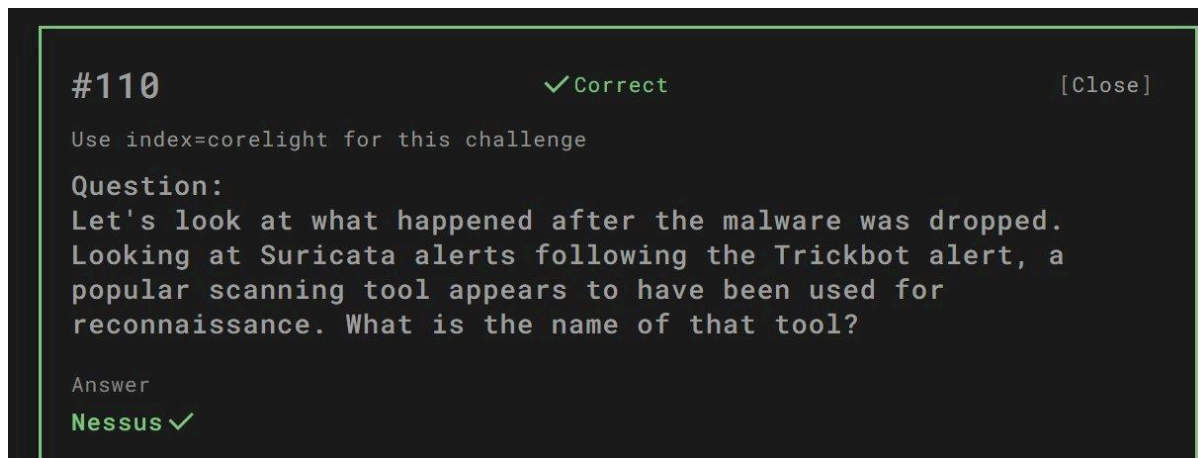
Q#109: POST body content showing exfiltrated process list — svchost.exe appears multiple times

Question #110 — Post-Infection Reconnaissance Tool

Looking at Suricata alerts following the Trickbot alert, a popular scanning tool appears to have been used for reconnaissance. What is the name of that tool?

Answer: Nessus

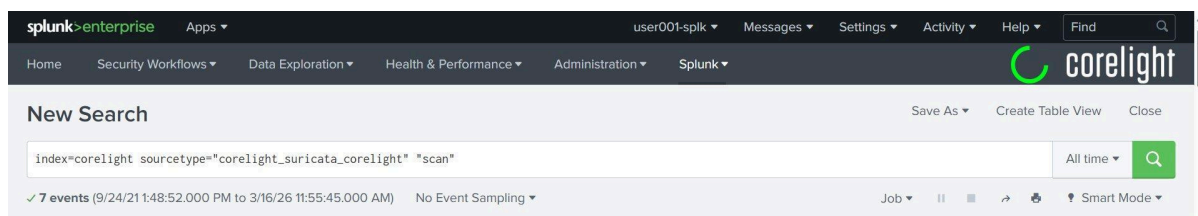
Step 1 — Question Card



Q#110: Question card confirming "Nessus" as the post-infection scanning tool

Step 2 — SPL Query: Suricata Alerts Mentioning "Scan"

Query: `index=corelight sourcetype="corelight_suricata_corelight" "scan"` — This filters Suricata alerts containing the keyword "scan" to identify reconnaissance-related signatures triggered after the Trickbot infection. 7 events are returned.



Q#110: Splunk search for "scan" keyword in Suricata alerts — 7 events found

Step 3 — Nessus Scanner Event Detail

The alert details show signature "ETPRO SCAN Nessus Scanner UPNP Broadcast" (category: Misc Attack, severity: 2). The origin host is 10.0.0.31 (the infected Trickbot host) scanning 10.0.0.43 — indicating post-compromise use of Nessus for internal network reconnaissance.

```
_write_ts: 2021-09-24T13:55:34.601347Z
alert.action: allowed
alert.category: Misc Attack
alert.gid: 1
alert.metadata: [ [+]
]
alert.rev: 2
alert.severity: 2
alert.signature: ETPRO SCAN Nessus Scanner UPNP Broadcast
alert.signature_id: 2803236
community_id: 1:zTxROJMshPHPp38Cu5Vn9et94Jo=
flow_id: 605100105403490
id.orig_h: 10.0.0.31
id.orig_p: 60996
id.resp_h: 10.0.0.43
```

Q#110: Suricata event showing "ETPRO SCAN Nessus Scanner UPNP Broadcast" — 10.0.0.31 → 10.0.0.43

Question #111 — Bytes Returned by WAP Exploit Target

One of the alerts generated by our infected host could result in command execution on a wireless access point. Looking at the response from the remote system, how many bytes did the target send back to the attacker on this connection?

Answer: 0

Step 1 — Question Card

#111
✓ Correct
[Close]

Use index=corelight for this challenge

Question:

One of the alerts generated by our infected host could result in command execution on a wireless access point. Looking at the response from the remote system, however, it's pretty clear that the attack failed. How many bytes did the target send back to the attacker on this connection?

Answer

0 ✓

Q#111: Question card confirming 0 bytes returned by the WAP target

Step 2 — Identifying the WAP Exploit Alert

Query: index=corelight | stats count by alert.signature — This broader signature summary reveals all alert types. The target signature must satisfy three conditions: (1) it must be an exploit (not just scanning), (2) it must relate to command execution, and (3) it must target a wireless access point or router.

New Search

Save As

Create Table View

Close

index=corelight | stats count by alert.signature

All time

✓ 226,463 events (9/24/21 1:48:52.000 PM to 3/16/26 12:18:34.000 PM) No Event Sampling

Job

II

Smart Mode

Events

Patterns

Statistics (19)

Visualization

20 Per Page

Format

Preview

alert.signature	count
ET DOS Possible NTP DDoS Inbound Frequent Un-Authed MON_LIST Requests IMPL 0x03	1
ET DOS Possible SSDP Amplification Scan in Progress	1
ET HUNTING GENERIC SUSPICIOUS POST to Dotted Quad with Fake Browser 1	8
ET HUNTING Suspicious POST with Common Windows Process Names - Possible Process List Exfiltration	4
ET MALWARE Win32/Trickbot Data Exfiltration	4
ET POLICY External IP Lookup (ipify .org)	1
ET POLICY HTTP traffic on port 443 (POST)	12

Q#111: Full Suricata signature summary — identifying exploit signatures from 10.0.0.31

Step 3 — Analytical Reasoning

Applying the three conditions to the full signature list identifies "ETPRO EXPLOIT Possible Asus WRT LAN Backdoor Command Execution" as the matching alert. ASUS WRT is a router/wireless access point firmware, "EXPLOIT" indicates this is an active exploitation attempt, and "Command Execution" is explicitly stated.

The question says:

"an alert generated by our infected host could result in command execution on a wireless access point."

So we need **three conditions**:

- 1 It must be an **exploit** (not just scanning or policy).
- 2 It must target **command execution**.
- 3 It must target a **wireless access point / router**.

Q#111: Analytical breakdown of the three conditions identifying the correct alert signature

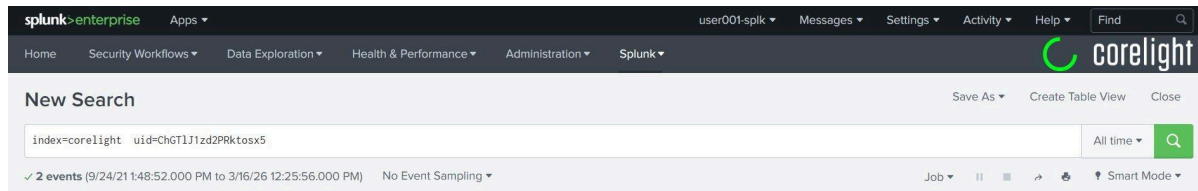
Step 4 — Exploit Event Detail

Query: index=corelight uid=ChGTIJ1zd2PRktosx5 — Searching by the UID from the exploit event reveals 2 events. The alert details show: alert.category: "Attempted Administrator Privilege Gain", alert.signature: "ETPRO EXPLOIT Possible Asus WRT LAN Backdoor Command Execution", id.orig_h: 10.0.0.31, id.resp_h: 10.0.0.43, id.resp_p: 9999. The service field shows "failed", indicating the exploit was unsuccessful.

i	Time	Event
>	9/24/21 1:55:34.641 PM	<pre>{ [-] _path: suricata_corelight _system_name: SmartPCAP_192_168_5_1 _write_ts: 2021-09-24T13:55:34.641716Z alert.action: allowed alert.category: Attempted Administrator Privilege Gain alert.gid: 1 alert.metadata: [[+]] alert.rev: 4 alert.severity: 1 alert.signature: ETPRO EXPLOIT Possible Asus WRT LAN Backdoor Command Execution alert.signature_id: 2809444 community_id: 1:k6rqnPqspKBSpCCvUllrmAnMuCE= flow_id: 442247830482833 id.orig_h: 10.0.0.31 id.orig_p: 36546 id.resp_h: 10.0.0.43 id.resp_p: 9999 pcap_cnt: 0 service: failed suri_id: Sx1VrmE3Mm6h ts: 2021-09-24T13:55:34.634769Z tx_id: 0 uid: ChGTIJ1zd2PRktosx5 }</pre>

Q#111: Full event detail — Asus WRT exploit attempt from 10.0.0.31 to 10.0.0.43:9999, service: failed

Step 5 — UID Search Confirming 2 Events



Q#111: Splunk search for uid=ChGTlJ1zd2PRkto5 returns 2 events (suricata alert + conn log)

Step 6 — Connection Log: Bytes Confirmation

The associated conn log entry (corelight_conn) shows resp_ip_bytes: 0 — confirming the target sent zero bytes in response, i.e., the WAP exploit attempt produced no response from the target and clearly failed.

```
missed_bytes: 0
orig_ip_bytes: 540
orig_l2_addr: 0c:44:14:16:00:00
orig_pkts: 1
pcr: 1
proto: udp
resp_ip_bytes: 0
resp_l2_addr: 10:d5:61:1d:8f:b7
resp_pkts: 0
spcap.rule: 6
----- 611 unassociated
```

Q#111: Conn log snippet showing resp_ip_bytes: 0, proto: udp — target returned nothing

Question #112 — Internal SSH Target After Infection

Looking at the layer 7 services used by the infected host after the Trickbot alerts, we see an SSH connection made to an internal host. What is the IP address of that host?

Answer: 10.0.0.72

Step 1 — Question Card

#112
✓ Correct
[Close]

Use `index=corelight` for this challenge

Question:
Looking at the layer 7 services used by the infected host after the Trickbot alerts above, we see an SSH connection made to an internal host. What is the IP address of that host?

Answer guidance: Provide the IPv4 address. Example: 192.168.1.1

Answer
10.0.0.72 ✓

Q#112: Question card confirming internal SSH target IP 10.0.0.72

Step 2 — SPL Query: SSH Connections from Infected Host

Query: `index=corelight sourcetype=corelight_conn id.orig_h=10.0.0.31 id.resp_p=22` — Filtering `corelight_conn` logs for outbound SSH connections (port 22) from the infected host 10.0.0.31 reveals the lateral movement attempt. 748 connection events are returned; examining them reveals the SSH destination host as 10.0.0.72.

The screenshot shows a Splunk search interface with the query `index=corelight sourcetype=corelight_conn id.orig_h=10.0.0.31 id.resp_p=22`. The results show 748 events. The event details for the first event are as follows:

Time	Event
9/24/21 2:55:36.264 PM	<pre>{ "_path": "conn", "_system_name": "SmartPCAP_192.168.5_1", "_write_ts": "2021-09-24T14:55:36.264682Z", "community_id": "1:V8r+y0v3S1pvUV5y1wSiVqRuBek=", "conn_state": "RSTO", "corelight_shunted": false, "duration": 0.039649009704589844, "history": "ShAdadRR", "id.orig_h": "10.0.0.31", "id.orig_h_name.src": "DNS_A", "id.orig_h_name.vals": ["*"], "id.orig_p": 54984, "id.resp_h": "10.0.0.72" }</pre>

Q#112: 748 SSH connection events from 10.0.0.31 to port 22 — event details show destination host 10.0.0.72

Question #113 — PCR of the SSH Session

What is the PCR (producer/consumer ratio) of that SSH session? (Rounded to 5 decimal places)

Answer: 0.85198

Step 1 — Question Card

#113 ✓ Correct [Close]

Use `index=corelight` for this challenge

Question:
What is the PCR (producer/consumer ratio) of that SSH session?

Answer guidance: Round your answer to 5 decimal places. Example:
2.34567

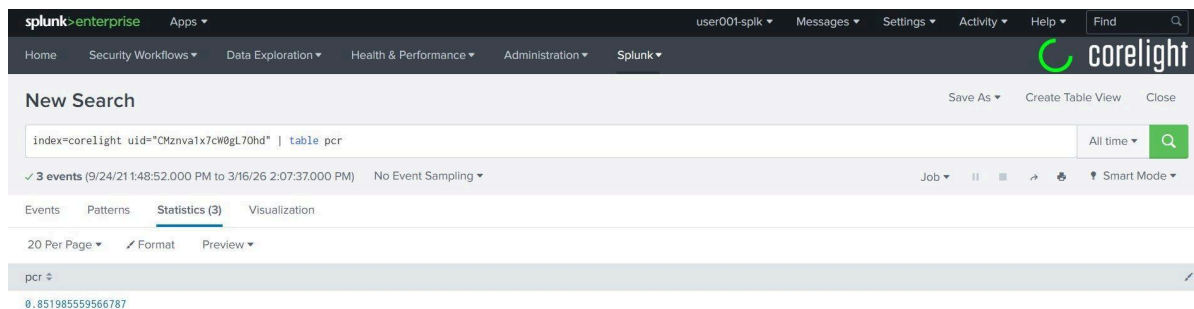
Answer

SUBMIT

Q#113: Question card confirming PCR value of 0.85198 for the SSH session

Step 2 — SPL Query: PCR from the SSH Session UID

Query: `index=corelight uid="CMznva1x7cW0gL70hd" | table pcr` — The PCR (Producer/Consumer Ratio) is a Corelight-specific field available in the `corelight_conn` log. A PCR close to 1 means the originator sent most of the data; a PCR close to -1 means the responder did. The raw value returned is 0.8519855559566787, which rounds to 0.85198. A PCR of ~0.85 indicates the infected host (10.0.0.31) was primarily sending data over the SSH tunnel — consistent with interactive command-line access or data exfiltration rather than passive file download.



Q#113: Splunk query "`index=corelight uid=CMznva1x7cW0gL70hd | table pcr`" → raw PCR value:
0.8519855559566787

Conclusions & Key Takeaways

This investigation successfully traced a complete Trickbot infection chain using Corelight network telemetry within Splunk. The key findings include:

- Infected host: 10.0.0.31 generated 224,755 of the 226,463 total events — nearly all traffic in the index.
- Trickbot C2 communication: The malware used HTTP with a distinctive "Ghost" User-Agent string to communicate with C2 server 103.16.104.83, exfiltrating a running process list via POST requests.
- MITRE ATT&CK mapping: Corelight's built-in notice detection correctly flagged the traffic as S0266 (Trickbot) with technique HTTP_C2::C2_Traffic_Observed.
- Post-infection actions: The attacker used Nessus for internal network reconnaissance and attempted a router backdoor exploit (Asus WRT) against 10.0.0.43:9999, which failed (0 bytes returned).
- Lateral movement: The infected host established SSH connections to internal host 10.0.0.72 with a PCR of 0.85198, suggesting command-line access or exfiltration over SSH.

Corelight's integration with Splunk proved highly effective — Zeek's rich network metadata (UIDs, PCR, L7 application labels, community IDs) enabled precise pivoting between log types, while Suricata alert integration provided signature-based threat identification with MITRE ATT&CK context out of the box.

Attack Timeline

The following timeline reconstructs the full Trickbot infection chain as observed in the Corelight network logs, from initial compromise through lateral movement.

INITIAL INFECTION	▼ 10.0.0.31 compromised with Trickbot malware
C2 COMMUNICATION	▼ HTTP POST requests to 103.16.104.83 (User-Agent: Ghost)
DATA EXFILTRATION	▼ Process list sent to C2 via POST body (T1071.001)
RECONNAISSANCE	▼ Nessus scanner used for internal network mapping (T1046)
EXPLOIT ATTEMPT	▼ Asus WRT LAN backdoor exploit against 10.0.0.43:9999 — FAILED (0 bytes returned)
LATERAL MOVEMENT	→ SSH connection to internal host 10.0.0.72 (PCR: 0.85198) (T1021.004)

MITRE ATT&CK Technique Mapping

The table below maps each observed attacker behavior to the corresponding MITRE ATT&CK technique, demonstrating the breadth of TTPs present in this single infection chain.

Phase	Technique ID	Technique Name	Evidence
Command & Control	T1071.001	Application Layer Protocol: Web Protocols	HTTP POST requests to 103.16.104.83 over port 443 with User-Agent "Ghost"
Exfiltration	T1041	Exfiltration Over C2 Channel	Process list exfiltrated via POST body on the same HTTP C2 channel
Discovery	T1057	Process Discovery	Running process list enumerated and sent to C2 (svchost.exe repeated)
Discovery	T1046	Network Service Discovery	Nessus scanner (ETPRO SCAN signature) used for internal network reconnaissance
Lateral Movement	T1021.004	Remote Services: SSH	SSH connection from 10.0.0.31 to 10.0.0.72 (PCR 0.85198)
Exploitation	T1190	Exploit Public-Facing Application	Asus WRT LAN backdoor exploit attempt against 10.0.0.43:9999 (failed)
Software	S0266	Trickbot (Software)	Identified by Suricata ET MALWARE signature and Corelight HTTP_C2 notice

Detection Opportunities

Based on the TTPs observed in this investigation, the following detection rules and monitoring strategies would significantly improve visibility into similar Trickbot-style attacks. These recommendations demonstrate a proactive, threat-informed defense approach aligned with the MITRE ATT&CK framework.

Anomalous HTTP User-Agent — T1071.001

Alert on HTTP requests using rare or single-word User-Agent strings such as "Ghost". Legitimate browsers use verbose, structured UA strings. A one-word UA with POST requests to a non-CDN IP should trigger high-confidence alerting.

Process List Enumeration via POST Body — T1057 / T1041

Monitor for HTTP POST bodies containing lists of Windows system process names (e.g., svchost.exe, lsass.exe, services.exe). This pattern is characteristic of Trickbot's system survey module.

Internal Nessus Scanning from Workstation — T1046

Alert on Nessus scanner signatures (ETPRO SCAN Nessus) originating from workstation IPs (non-scanner subnets). Nessus activity from a user endpoint is a strong post-compromise indicator.

Workstation-to-Workstation SSH Connections — T1021.004

Flag lateral SSH traffic between internal workstations (not server-to-server or admin-to-server). SSH from a workstation to another workstation is rarely legitimate and should be investigated.

Router/IoT Exploit Signatures — T1190

Monitor for ETPRO EXPLOIT signatures targeting embedded devices (routers, WAPs, printers). Trickbot and other malware families attempt to compromise network infrastructure after establishing a foothold.

Corelight HTTP C2 Notice Events — S0266

Operationalize Corelight's built-in HTTP_C2::C2_Traffic_Observed notices as high-priority alerts in your SIEM. These notices include MITRE software IDs and should auto-generate investigation tickets.